

When a tool helps count the dead, *"it works"* isn't enough.

RMS estimates excess mortality for Sierra Leone. The numbers can shape a public-health response, so before it shipped it cleared **8 layers of AI governance**. Here is every layer, on this one build.

Speed is easy. *Defensible* is the job.

AI can produce a mortality estimate in seconds. But if one death was counted twice, or the data was stale, the number is wrong. And a wrong number sends a response to the wrong place.

Governance is what turns a raw output into a number someone can **stand behind**.

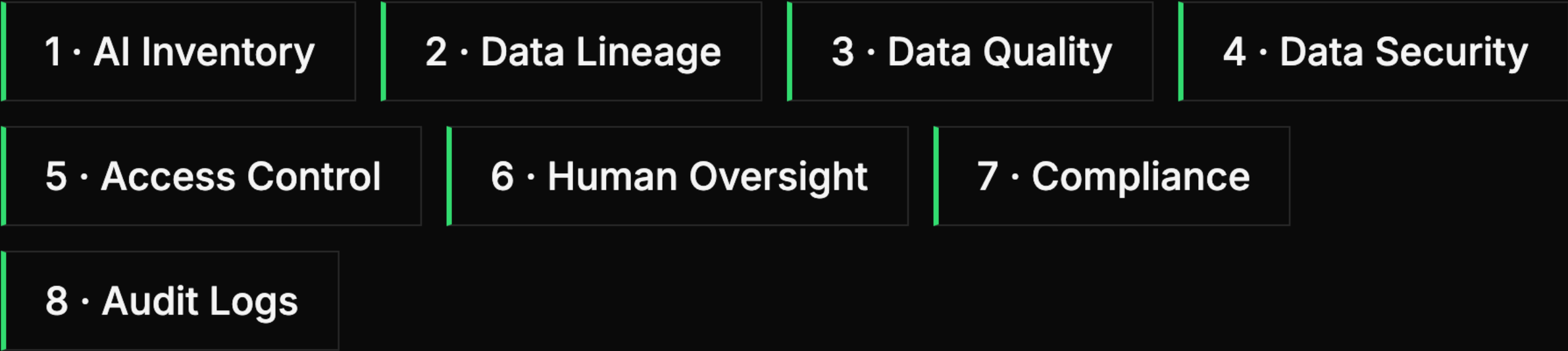
One intake. So a death is never counted *twice*.

RMS is a single-source death tracker feeding a code-exact excess-mortality calculator. It draws from DHIS2 and the civil register through one intake, so the same death from two registers counts once.

- Risk tier T1 high-risk. Mortality records are special-category data.
- The engine is statistical, not an LLM. Governed as high-stakes decision-support all the same.
- Live in production. 338 backend tests, 8 migrations.

Eight layers. Every AI surface answers all *eight*.

The risk tier sets the depth, not the checklist. Here is the full stack, top to bottom.



Know every AI you actually *run*.

Nothing reaches production unregistered. This is the backstop against shadow AI.

- RMS is on the portfolio register. Its two algorithmic systems are listed, not floating.
- Classified, tiered T1, owner named. Interpretation stays with analysts and MoHS.
- A statistical engine still counts. If it decides, it is on the register.

Trace every number back to its *source*.

Every excess-mortality figure ties back to the exact records, org unit, window and baseline that produced it.

- Single intake by design. A death in two registers counts once. The core lineage control.
- Every source adapter named. DHIS2, OpenCRVS, Excel, KoBo backfill.
- A code-exact rebuild of a published calculator. The math matches a known reference.

Bad data in, bad decisions *out.*

The model is never fed data the pipeline has not validated and de-duplicated.

- Deterministic record-linkage de-dupes the same death across sources. The product's whole reason to exist.
- Schema validation at ingestion. Org-unit hierarchy, facility type and GPS all checked.
- 338 backend tests guard the methodology engine and the intake.

Encrypt it. Isolate it. *Log* the access.

One breached component should never expose a plaintext record.

- Encrypted in transit and at rest. TLS, an encrypted volume, and AES-256 backups that fail closed without a passphrase.
- Only the web tier is public. Database and backend stay internal. ufw and fail2ban on the host.
- Its own dedicated server. Separate from every other product, to shrink the blast radius.

Least privilege. Enforced at the *API*.

Every actor holds the minimum access for their task, checked server-side, not hidden in the UI.

- Typed roles: DATA_ENTRY, ANALYST, ADMIN. Mortality data is not open to every login.
- Password rotation, reuse blocking, force-change-on-reset, idle screen-lock.
- Admin controls with self-lockout and last-admin guards built in.

AI decides *nothing* alone.

The calculator informs human public-health judgment. It does not trigger action on its own.

- Analysts read an excess-mortality band, not a single confident number.
- Outputs always carry their uncertainty. Observed against a 95% confidence band.
- The statistical model is an explicit human choice, never a hidden default.

Map the build to the *rules*.

For this system we can show the regimes that apply, the assessment, and the controls that satisfy them.

- Mapped to the SL Data Protection Act 2023, the Africa CDC framework, and GDPR Articles 9 and 35.
- A full DPIA written for the special-category mortality data before scale.
- No external AI sub-processor. The data does not leave the system to a third-party model.

If you can't prove it, it didn't *happen*.

Any consequential action can be reconstructed after the fact.

- User activity and change trails per account.
- Deploy and migration events recorded through a deliberate, single-config release flow.
- Next on the roadmap: log which baseline and window produced each estimate, so any published number is reproducible.

GOVERN EVERY BUILD

Same eight questions. *Every* build.

Patient records, mortality data, a content pipeline: the layers do not change. The risk tier just sets how hard each one is enforced.

Ungoverned AI on real people is not a shortcut. **It is a liability you have not measured yet.**

I build everything this way, and I share the methods in public. **Follow along.**

Building something that has to be trusted? **Let's talk.**